CarbonWasteprint

DPIA BANCA DATI UTENZE

Portale Carbon WastePrint®

Traccia di valutazione d'impatto sulla protezione dei dati (art. 35 GDPR) da completare con il Comune

DOCUMENTO	REVISIONE	DATA DI REVISIONE
DPIA Banca Dati Utenze	Rev. 1.2	31/10/2026

Programma di

Fondazione operate

RISERVATO AGLI AMMINISTRATORI

Il documento

Questa traccia descrive come il portale tratta la Banca Dati Utenze (dati, flussi, chi vede cosa, servizi usati, misure di sicurezza) e propone la valutazione dei rischi. Il Comune, titolare del trattamento, la completa con il suo DPO nelle parti segnate «da completare». Non è un parere legale.

Destinatari	Amministratori della Fondazione, Comuni e loro DPO — documento riservato
Revisione corrente	Rev. 1.2 del 31/10/2026
Redatto da	Fondazione Operate
Versione sempre aggiornata	Area Documentazione del portale (solo Amministratori)

Registro delle revisioni

Rev.	Data	Descrizione	Autore
1.2	31/10/2026	Pseudonimizzazione (azione A1) in produzione dal 31/10/2026.	Fondazione Operate
1.1	30/10/2026	Pseudonimizzazione applicata nel portale (azione A1): Banca Dati Utenze senza nomi e indirizzi.	Fondazione Operate
1.0	26/10/2026	Prima stesura della traccia (richiesta di Luca del 26/10): descrizione del trattamento, servizi e luogo dei dati (Supabase in Germania), rischi, misure presenti, piano d'azione, parti da completare dal Comune e dal DPO.	Fondazione Operate

Sommario

01 Come usare questa traccia 4

02 Dati identificativi 6

03 Perché serve la DPIA 7

04 Descrizione del trattamento 8

05 Ruoli e base giuridica 12

06 Necessità e proporzionalità 13

07 Rischi per le persone 15

08 Misure già presenti nel portale 17

09 Piano d'azione prima dei dati reali 19

10 Rischio residuo e consultazione del Garante 21

11 Parere del DPO 22

12 Approvazione del titolare 23

01

Come usare questa traccia

Questa è una **traccia di valutazione d'impatto sulla protezione dei dati** (in inglese *DPIA*, articolo 35 del Regolamento UE 2016/679, «GDPR») per la **Banca Dati Utenze** del portale Carbon WastePrint®: l'elenco delle utenze TARI di un Comune che serve a calcolare i crediti.

La parte che descrive **il portale** (dati, flussi, chi vede cosa, servizi usati, misure di sicurezza) è già scritta dalla Fondazione Operate, che gestisce il portale. Le parti che spettano **al Comune** sono lasciate in bianco e segnate così: **[da completare dal Comune]**.

Chi fa che cosa.

Chi	Ruolo nella DPIA
Comune (titolare del trattamento)	Completa le parti in bianco, decide la base giuridica, approva la valutazione e la conserva. La DPIA è un obbligo del titolare
DPO del Comune (Responsabile della protezione dei dati)	Dà il suo parere scritto (articolo 35, paragrafo 2), nel capitolo «Parere del DPO»
Fondazione Operate (responsabile del trattamento, da confermare nell'accordo)	Fornisce le informazioni sul portale e attua le misure; collabora con il Comune (articolo 28, paragrafo 3, lettera f)

Come procedere.

1. La Fondazione manda al Comune questa traccia in Word (pulsante **Scarica Word** dell'area Documentazione).
2. Il Comune e il suo DPO completano le parti in bianco e rivedono le valutazioni dei rischi: quelle scritte qui sono la **proposta della Fondazione**, non una decisione.
3. Il Comune firma la conclusione e manda alla Fondazione una copia: la Fondazione la conserva con l'accordo sul trattamento (articolo 28).
4. Il Comune carica nel portale le utenze reali **solo dopo** la DPIA approvata e l'accordo firmato.

DA SAPERE

ATTENZIONE

Attenzione. Questa traccia non è un parere legale. È scritta da chi gestisce il portale per descriverlo in modo completo e onesto; la valutazione finale spetta al Comune con il suo DPO o un consulente legale.

Riferimenti. Regolamento UE 2016/679 (articoli 5, 6, 25, 28, 30, 32-36, 44-49); Linee guida WP248 rev.01 del Gruppo di lavoro Articolo 29 sulla valutazione d'impatto; Provvedimento del Garante n. 467 dell'11/10/2018 (elenco dei trattamenti soggetti a DPIA); D.Lgs. 196/2003 come modificato dal D.Lgs. 101/2018.

02

Dati identificativi

Voce	Contenuto
Titolare del trattamento	**[da completare dal Comune]** Comune di ....., sede ....., PEC .....
DPO del Comune	**[da completare dal Comune]** Nome ....., contatto .....
Responsabile del trattamento	Fondazione Operate, che gestisce il Programma Carbon WastePrint® e il portale
Referente della Fondazione per la protezione dei dati	**[da completare dalla Fondazione]** .....
Trattamento valutato	Banca Dati Utenze per il calcolo dei crediti di carbonio del Programma Carbon WastePrint®
Progetto CWP collegato	**[da completare]** codice ..... (es. CWP-2026-0001)
Data della valutazione	**[da completare]** .....
Versione	Traccia preparata dalla Fondazione, revisione indicata in copertina

03

Perché serve la DPIA

La DPIA è obbligatoria quando un trattamento può presentare un **rischio elevato** per i diritti delle persone. Le Linee guida WP248 indicano nove criteri: con **due o più** criteri la DPIA è di norma necessaria. Per la Banca Dati Utenze la Fondazione propone questa lettura.

Criterio (WP248)	Presente?	Perché
Valutazione o punteggio delle persone	In parte	I kg conferiti e gli svuotamenti di ogni utenza misurano il comportamento della famiglia o dell'attività, anche se il calcolo non dà un giudizio sulla singola utenza
Decisioni automatiche con effetti giuridici	No	Il calcolo non decide nulla sul singolo utente: non cambia la bolletta TARI e non produce comunicazioni agli utenti
Monitoraggio sistematico	In parte	I dati vengono dalla misurazione puntuale dei conferimenti, raccolta ogni anno
Dati sensibili o molto personali	No	Nessun dato di categorie particolari (salute, religione…); nome, indirizzo e abitudini di conferimento sono però dati personali comuni da proteggere
Trattamento su larga scala	**Sì**	Tutte le utenze del Comune, domestiche e non domestiche, ogni anno (migliaia di famiglie per Comune)
Incrocio o combinazione di insiemi di dati	**Sì**	I dati nascono per la TARI (Comune o gestore) e vengono usati per un'altra finalità, il calcolo dei crediti, da un altro soggetto
Interessati vulnerabili	No	Cittadini e attività in generale; nessuna categoria specifica
Uso innovativo di tecnologie	No	Portale web e database tradizionali; nessuna intelligenza artificiale sui dati delle utenze
Trattamento che impedisce di esercitare un diritto o usare un servizio	No	Il servizio di raccolta e la TARI non dipendono da questo trattamento

Conclusione proposta: almeno due criteri sono presenti (larga scala; dati raccolti per un'altra finalità), quindi la DPIA è **consigliata come necessaria**. **[da confermare dal Comune e dal DPO]**

04
Descrizione del trattamento

Finalità

Calcolare, per ogni anno di monitoraggio, la **riduzione delle emissioni** ottenuta dal Comune con la tariffa puntuale e le azioni di riduzione dei rifiuti, secondo la Metodologia del Programma Carbon WastePrint®. Il risultato (crediti di carbonio) appartiene al Comune ed è verificato da un Ente di Validazione indipendente.

Il calcolo confronta, **per ogni utenza**, i rifiuti **attesi** (dalla classe o categoria della delibera TARI) con i rifiuti **prodotti** (dai conferimenti misurati). Per questo serve una riga per utenza e non solo i totali del Comune.

Finalità escluse. I dati delle utenze **non** si usano per controlli tributari, marketing, profilazione commerciale, comunicazioni agli utenti o cessioni a terzi. Il modulo Marketing del portale usa solo dati pubblici degli enti (Comuni e gestori) e non legge la Banca Dati Utenze.

Interessati

- **Intestatari delle utenze domestiche** (capofamiglia), e indirettamente i componenti del nucleo familiare (solo il numero, non i nomi).
- **Utenze non domestiche**: attività, enti e uffici. Sono dati personali solo quando l'intestatario è una persona fisica (ditte individuali, professionisti).

Numero indicativo di utenze del Comune: **[da completare dal Comune]** ..... domestiche, ... non domestiche.

Dati trattati

Il modello **Banca dati utenze CWP** (un foglio per le domestiche, uno per le non domestiche) contiene, per ogni utenza dell'anno:

Dato	Obbligatorio	Natura
Codice utenza (es. codice TARI)	Sì	Identificativo indiretto
Categoria tariffaria TARI	No	Dato tecnico
Numero di componenti (solo domestiche)	No	Dato personale (composizione della famiglia)
Metri quadrati	No	Dato personale
Produzione totale di rifiuti (kg/anno)	Sì	Dato personale (comportamento)
Kg per frazione (indifferenziato obbligatorio; organico, carta, plastica, vetro...)	In parte	Dato personale (comportamento)

Dato	Obbligatorio	Natura
Numero di svuotamenti per frazione	No	Dato personale (comportamento)

Dati che non ci sono e non si caricano: nome del capofamiglia o ragione sociale e indirizzo (dal 31/10/2026: il portale non li chiede e, se un file li contiene, li ignora), codice fiscale, data di nascita, telefono, email, dati di pagamento, situazione economica, riduzioni o agevolazioni (che potrebbero rivelare condizioni di salute o di disagio).

Il portale aggiunge un solo campo: la **categoria di simulazione** (la classe della delibera usata dal calcolo).

> **DA SAPERE**
>
> **Il punto più importante della valutazione.** Per calcolare i crediti **nome e indirizzo non servono**: basta il codice dell'utenza. Dal 31/10/2026 il portale applica la **pseudonimizzazione** (capitolo «Necessità e proporzionalità», Proposta 1): il modello non ha più nomi e indirizzi, il Comune manda solo i codici e tiene per sé la corrispondenza codice-intestatario. Così la maggior parte dei rischi descritti più avanti si riduce molto.

Ciclo di vita dei dati

Passo	Cosa succede	Chi
1. Raccolta	Il Comune o il suo gestore estrae dal proprio sistema TARI e di misurazione l'elenco delle utenze dell'anno e compila il modello	Comune / gestore
2. Trasmissione	Il file arriva alla Fondazione **[da completare: canale sicuro concordato, es. PEC o cartella condivisa protetta; mai email ordinaria non protetta]**	Comune → Fondazione
3. Caricamento	Un Amministratore della Fondazione carica il file nel calcolo dell'anno. Il file viene letto **nel browser**: il portale salva solo le righe delle utenze nel database, il file originale non viene conservato nel portale	Fondazione (solo Amministratori)
4. Controllo	Il portale segnala errori (codici doppi, numeri non validi, totale diverso dalla somma delle frazioni)	Portale
5. Calcolo	Il motore di calcolo usa le utenze per i rifiuti attesi e prodotti e produce i risultati aggregati	Portale
6. Verifica	L'Ente di Validazione vede i **risultati aggregati** e il rapporto di calcolo, **senza** nomi né indirizzi	Ente di Validazione
7. Conferma	Il calcolo confermato non si modifica più (anche le sue utenze)	Fondazione
8. Conservazione	Oggi i dati restano con la pratica per 12 anni (Guida al Programma 6.2.1 e 6.5.1). Per le utenze la Fondazione propone un periodo diverso (capitolo «Necessità e proporzionalità»)	Fondazione
9. Cancellazione	**[da definire nell'accordo]** alla fine del periodo, o alla fine dell'accordo, su istruzione del Comune	Fondazione

Chi vede i dati nel portale

Chi	Che cosa vede
Amministratori della Fondazione	Elenco completo, modulo di ogni utenza; possono caricare, modificare e cancellare (solo in un calcolo non confermato)
Operatori della Fondazione	Elenco e modulo delle utenze in sola lettura
Utenti del Comune nel portale	**Non vedono** la Banca Dati Utenze (vedono solo le loro pratiche e i risultati)
Ente di Validazione	Non vede la Banca Dati Utenze; vede i risultati aggregati
Pubblico (pagina /programma, feedback pubblico)	Nulla delle utenze; solo dati aggregati del Progetto
Assistente virtuale del portale (Claude, Anthropic)	**Non riceve** i dati delle utenze

Ogni consultazione dell'elenco viene registrata nell'**Audit** del portale («consultazione utenze», con chi, quando e la ricerca fatta), come ogni caricamento (con il solo numero di utenze), modifica e cancellazione (con il codice dell'utenza, senza nomi né indirizzi).

Dove stanno i dati e servizi usati

Il portale non ha server propri: usa servizi in cloud. Questa è la mappa di dove passano i dati delle utenze.

Servizio	Società	Ruolo	Dati delle utenze?	Dove
Supabase (database, accessi, funzioni)	Supabase Inc. (USA)	Sub-responsabile	**Sì**: tutte le righe caricate	Server in **Germania (Francoforte)**, Unione Europea
Vercel (pubblicazione del sito)	Vercel Inc. (USA)	Sub-responsabile	**No**: distribuisce le pagine del portale; i dati vanno direttamente dal browser a Supabase	Rete mondiale
Resend (email di notifica)	Resend Inc. (USA)	Sub-responsabile	**No**: solo nome ed email degli utenti del portale che ricevono le notifiche	**[da verificare: regione del servizio]**
Anthropic (assistente virtuale e strumenti di sviluppo Claude)	Anthropic PBC (USA)	Sub-responsabile per l'assistente	**No** per l'assistente. Vedi nota sugli strumenti di manutenzione	USA
Google Drive (copia di sicurezza giornaliera)	Google (USA, sede UE in Irlanda)	Sub-responsabile	**Sì**: la copia completa del database contiene anche le utenze	**[da verificare]**
Computer della Fondazione (copia di sicurezza)	—	—	**Sì**: la copia giornaliera passa dal computer di Luca Moretti prima di Google Drive	Italia

Servizio	Società	Ruolo	Dati delle utenze?	Dove
GitHub (codice del portale)	GitHub Inc. (USA)	—	**No**: contiene solo il codice, mai dati	—

Trasferimenti fuori dall'Unione Europea. I dati delle utenze sono conservati in Germania. Le società dei servizi hanno però sede negli Stati Uniti, per cui per gli accessi di assistenza tecnica e per l'applicazione di leggi statunitensi (es. CLOUD Act) va considerato un possibile accesso da fuori UE. Servono, per ciascun sub-responsabile che tratta le utenze: accordo sul trattamento (DPA), adesione all'EU-US Data Privacy Framework oppure clausole contrattuali tipo, e la verifica della sede di conservazione. **[da verificare dalla Fondazione per Supabase e Google; da riportare nell'accordo]**

Nota sugli strumenti di manutenzione. Lo sviluppo e la manutenzione del portale sono fatti con l'aiuto di Claude (Anthropic), che lavora sotto l'account di un Amministratore e può aprire l'editor del database. Con dati reali delle utenze la Fondazione si impegna a una regola: nelle sessioni di manutenzione **non si leggono le tabelle delle utenze** (calcolo_utenza); i controlli si fanno su dati inventati o su conteggi.

05
Ruoli e base giuridica

Ruoli

- **Comune: titolare del trattamento.** I dati delle utenze nascono dalla gestione della TARI e della raccolta, che sono compiti del Comune; il Comune decide di partecipare al Programma e di usare quei dati per il calcolo dei crediti.
- **Fondazione Operate: responsabile del trattamento** (articolo 28): tratta i dati solo per conto del Comune e secondo le sue istruzioni, con un **accordo scritto**. **[da confermare nell'accordo: se la Fondazione usasse i dati anche per finalità proprie, sarebbe titolare autonomo o contitolare e la valutazione cambierebbe]**
- **Gestore del servizio di raccolta**: se è il gestore a estrarre e mandare i dati, va chiarito il suo ruolo rispetto al Comune. **[da completare dal Comune]**
- **Sub-responsabili** della Fondazione: i servizi indicati nella tabella sopra; il Comune li autorizza nell'accordo.

Base giuridica

[da completare dal Comune] La Fondazione indica i punti da valutare:

- **Base del trattamento originario:** la gestione della TARI e della raccolta (articolo 6, paragrafo 1, lettere c ed e: obbligo di legge e compito di interesse pubblico), con la normativa di settore. .....
- **Compatibilità della nuova finalità** (articolo 6, paragrafo 4): il calcolo delle emissioni evitate è collegato alla gestione dei rifiuti e alle politiche ambientali del Comune; ma i crediti hanno anche un valore economico. Va valutato il legame tra le finalità, il contesto, la natura dei dati, le conseguenze per gli interessati e le garanzie (in particolare la pseudonimizzazione). .....
- **Atto del Comune** che decide la partecipazione al Programma (delibera o determina): .....

Informazione agli interessati

Il Comune aggiorna la propria **informativa TARI** (articoli 13 e 14) indicando la nuova finalità, la Fondazione come responsabile e i tempi di conservazione. **[da completare dal Comune: dove e quando viene pubblicata]**

06

Necessità e proporzionalità

Principio	Come si applica	Valutazione proposta
Minimizzazione	Il calcolo richiede una riga per utenza, la categoria, i componenti o i mq e i kg per frazione. **Nome e indirizzo non sono necessari al calcolo** e dal 31/10/2026 il portale non li tratta	Adeguato (pseudonimizzazione applicata, Proposta 1)
Limitazione della finalità	I dati si usano solo per il calcolo; nessun altro modulo del portale li legge	Adeguato
Esattezza	Controlli all'arrivo del file (codici doppi, numeri, totali); le correzioni si fanno nel modulo dell'utenza e sono registrate nell'Audit	Adeguato
Limitazione della conservazione	Oggi la pratica si conserva 12 anni; per le utenze serve un periodo proprio	**Da decidere**: vedi proposta qui sotto
Integrità e riservatezza	Misure tecniche e organizzative del capitolo «Misure»	Adeguato, con le azioni del piano
Diritti degli interessati	Accesso, rettifica, opposizione e cancellazione si esercitano verso il Comune; la Fondazione lo aiuta a rispondere entro i termini (articolo 28, paragrafo 3, lettera e)	Adeguato, da scrivere nell'accordo

Proposta 1 — Pseudonimizzazione (consigliata). Il Comune manda solo il **codice dell'utenza** (o un codice creato apposta, diverso dal codice TARI) e tiene presso di sé la tabella di corrispondenza con nomi e indirizzi. **Applicata nel portale dal 31/10/2026** (rilievo T29 del collaudo, scelta di Luca Moretti): il modello «Banca dati utenze CWP» non ha più le colonne «Nome» e «Indirizzo», il portale ignora quelle colonne nei file vecchi e non le salva. Effetti:

- il portale contiene dati **pseudonimizzati**: restano dati personali per il Comune, ma nessuno nel portale può risalire alla persona senza la tabella del Comune;
- un accesso non autorizzato, un errore o una copia di sicurezza persa avrebbero conseguenze molto più leggere;
- il calcolo dei crediti non cambia.

Resta al Comune scegliere se usare il codice TARI o un codice creato apposta. **[scelta del Comune: .....]**

Proposta 2 — Conservazione delle utenze. I **risultati** del calcolo si conservano con la pratica per 12 anni, come chiede la Guida al Programma. Per le righe delle utenze la Fondazione propone di valutare con il Comune e con il Programma una di queste soluzioni:

- con la pseudonimizzazione: conservare le righe (solo codici) per i 12 anni, perché servono a ripetere o verificare il calcolo;
- senza pseudonimizzazione: togliere nome e indirizzo dopo la **verifica del Rapporto di Monitoraggio** e conservare solo codici e quantità.

[decisione del Comune: periodo e modalità .....]

07

Rischi per le persone

La valutazione guarda ai rischi **per gli interessati** (non per il Comune o la Fondazione). Scala usata: probabilità e gravità **bassa, media, alta**. I valori sono la proposta della Fondazione **con le misure già presenti** nel portale; la colonna «Livello» è stata stimata prima della pseudonimizzazione (applicata dal 31/10/2026, azione A1), quindi è prudente; la colonna a destra indica il livello dopo il piano d'azione.

N.	Rischio	Conseguenze per le persone	Probabilità	Gravità	Livello	Dopo il piano
R1	Accesso non autorizzato con l'account di un Operatore o Amministratore (password rubata o indovinata)	Nomi, indirizzi e abitudini di conferimento letti da estranei	Media	Media	**Medio**	Basso (verifica in due passaggi, pseudonimizzazione)
R2	Furto o perdita della copia di sicurezza (computer, Google Drive)	Come R1, su tutte le utenze	Media	Media	**Medio**	Basso (disco cifrato, copia senza nomi)
R3	Uso dei dati per finalità diverse (controlli, pubblicità, cessione)	Uso inatteso dei dati; perdita di fiducia	Bassa	Media	Basso	Basso
R4	Pubblicazione per errore (rapporti, fascicoli, pagina pubblica, feedback)	Dati della famiglia visibili a chiunque	Bassa	Alta	**Medio**	Basso
R5	Accesso da autorità o tecnici fuori dall'UE tramite le società statunitensi	Dati letti fuori dall'UE senza garanzie equivalenti	Bassa	Media	Basso	Basso (DPA, Data Privacy Framework o clausole tipo, pseudonimizzazione)
R6	Conservazione più lunga del necessario	Dati esposti più a lungo ai rischi R1-R4	Alta (oggi 12 anni)	Bassa	**Medio**	Basso (Proposta 2)
R7	Caricamento del file sbagliato (altro anno, altro Comune) o dati inesatti	Dati di persone trattati senza motivo; risultati sbagliati	Media	Bassa	Basso	Basso

N.	Rischio	Conseguenze per le persone	Probabilità	Gravità	Livello	Dopo il piano
R8	Lettura dei dati durante la manutenzione con strumenti di intelligenza artificiale	Dati letti da un servizio esterno	Bassa	Media	Basso	Basso (regola di manutenzione)
R9	Indisponibilità o perdita dei dati (guasto, cancellazione)	Per le persone quasi nessuna: i dati originali restano al Comune	Bassa	Bassa	Basso	Basso
R10	Difficoltà per gli interessati a esercitare i loro diritti	Richieste senza risposta nei tempi	Bassa	Bassa	Basso	Basso (procedura nell'accordo)

[da rivedere dal Comune e dal DPO: .....]

08
Misure già presenti nel portale

Accesso e permessi

- Accesso con email e password personali; nessun account condiviso.
- **Regole di sicurezza del database (RLS)**: la tabella delle utenze non si legge direttamente; si legge solo con due funzioni riservate a Operatori e Amministratori, che registrano chi ha consultato.
- Caricamento, modifica e cancellazione **solo** degli Amministratori; i Comuni, gli Enti di Validazione e il pubblico non vedono le utenze.
- **Uscita automatica** dopo 30 minuti di inattività per Operatori e Amministratori (avviso 2 minuti prima).
- **Verifica in due passaggi** (codice dall'app del telefono) pronta per Operatori e Amministratori; oggi spenta per decisione della Fondazione (vedi piano d'azione).
- **Avvisi di sicurezza** all'Amministratore principale: tentativi di accesso falliti ripetuti, molti tentativi su più account, nomina di un nuovo Amministratore.
- Registro degli accessi (Audit User → Accessi) con entrate, uscite e tentativi falliti.

Tracciabilità e integrità

- **Audit** non modificabile: consultazioni, caricamenti, modifiche e cancellazioni delle utenze, con chi e quando; nell'Audit non compaiono nomi né indirizzi.
- Un **calcolo confermato** non si modifica più, utenze comprese.
- Controlli automatici sul file all'arrivo (righe con errori: il file non si carica).

Riservatezza dei risultati

- Nomi e indirizzi **non compaiono** nei rapporti di calcolo, nei fascicoli scaricabili, nella pagina pubblica del Programma né nel feedback pubblico.
- Il **tracciato** dei conferimenti (formato precedente) è controllato prima dell'import: se contiene nomi, codici fiscali, indirizzi, email o telefoni il portale lo **blocca**.
- L'assistente virtuale non riceve i dati delle utenze.

Protezione tecnica

- Collegamenti solo in **https** (dati cifrati durante il trasferimento); il sito non si può incorporare in altre pagine e si collega solo al proprio database.
- Database in **Germania** (Unione Europea); cifratura dei dati conservati secondo la documentazione del fornitore.
- Il file originale non viene conservato nel portale: si leggono solo le righe.
- Funzioni del database con permessi ridotti al minimo e controllate con lo strumento di sicurezza del fornitore (Security Advisor) dopo ogni modifica.
- Controllo delle librerie del portale a ogni rilascio (nessuna vulnerabilità nota al 20/10/2026).
- **Copia di sicurezza** giornaliera completa e istruzioni di ripristino scritte.

Organizzazione

- Poche persone con accesso (Amministratori e Operatori della Fondazione), create dagli Amministratori; l'Amministratore principale riceve un avviso per ogni nuovo Amministratore.
- Manuali e registri aggiornati a ogni modifica del portale; le modifiche al database si fanno solo con l'approvazione esplicita del responsabile del portale.

09

Piano d'azione prima dei dati reali

Azioni proposte dalla Fondazione, da completare **prima** del caricamento delle utenze reali.

N.	Azione	Rischi	Chi	Stato
A1	**Pseudonimizzazione** (Proposta 1): modello e portale senza nomi e indirizzi	R1, R2, R4, R5, R6	Fondazione	**Fatto il 31/10/2026** (in produzione)
A2	Accendere la **verifica in due passaggi** per Operatori e Amministratori	R1	Fondazione	Da fare
A3	Firmare l'**accordo sul trattamento** (articolo 28) con istruzioni, sub-responsabili autorizzati, durata, cancellazione, assistenza per i diritti e per le violazioni	Tutti	Comune e Fondazione	Da fare
A4	Accettare i **DPA** dei fornitori che trattano le utenze (Supabase, Google) e verificare le garanzie per i trasferimenti fuori UE; verificare la regione di Resend	R5	Fondazione	Da fare
A5	Proteggere le **copie di sicurezza**: disco del computer cifrato, accesso a Google Drive con verifica in due passaggi, valutare una copia senza le colonne con nomi e indirizzi	R2	Fondazione	Da fare
A6	Decidere il **periodo di conservazione** delle utenze (Proposta 2) e la procedura di cancellazione	R6	Comune e Fondazione	Da decidere
A7	Concordare il **canale sicuro** di trasmissione del file	R2, R7	Comune e Fondazione	Da fare
A8	Procedura per le **violazioni dei dati** (data breach): la Fondazione avvisa il Comune senza ingiustificato ritardo (entro **[da completare]** ore) perché il Comune possa notificare al Garante entro 72 ore	Tutti	Fondazione	Da fare
A9	**Registro dei trattamenti** della Fondazione come responsabile (articolo 30, paragrafo 2) e **autorizzazione scritta** delle persone che accedono (articolo 29)	R1, R3	Fondazione	Da fare
A10	Regola di manutenzione: nessuna lettura delle tabelle delle utenze nelle sessioni con strumenti di intelligenza artificiale	R8	Fondazione	Da adottare
A11	Aggiornare l'**informativa TARI** del Comune	R3, R10	Comune	Da fare

N.	Azione	Rischi	Chi	Stato
A12	Verifica di sicurezza informatica del portale (OWASP) e controllo antivirus dei file caricati	R1	Fondazione	Da fare

10
Rischio residuo e consultazione del Garante

Valutazione proposta. Con le misure presenti e il piano d'azione completato (in particolare A1, A2, A3, A5), il rischio residuo per gli interessati è **basso**. Non sembra quindi necessaria la consultazione preventiva del Garante (articolo 36), che serve quando il rischio resta elevato nonostante le misure.

[da confermare dal Comune]

- Rischio residuo: ☐ basso ☐ medio ☐ elevato (consultazione del Garante)
- Azioni del piano completate prima dell'avvio: .....
- Prossima revisione della DPIA: ..... (consigliata ogni anno, prima del caricamento dei dati del nuovo anno, e a ogni cambiamento del trattamento)

Quando rifare la valutazione. La DPIA va rivista quando cambia il trattamento: nuovi campi nel modello, nuove persone o enti che vedono le utenze, nuovi servizi o un diverso luogo dei dati, modifica dei tempi di conservazione, oppure dopo una violazione dei dati. La Fondazione segnala al Comune ogni modifica del portale che tocca le utenze.

11 Parere del DPO

[da completare dal DPO del Comune]

Parere: ☐ favorevole ☐ favorevole con condizioni ☐ non favorevole

Osservazioni e condizioni:

.....

.....

Nome e firma del DPO: ..... Data: .....

12
Approvazione del titolare

[da completare dal Comune]

Il titolare, visto il parere del DPO, ☐ approva la valutazione e autorizza il trattamento alle condizioni indicate ☐ non autorizza il trattamento.

Se il titolare non segue il parere del DPO, ne indica i motivi: .....

Nome, ruolo e firma: ..... Data: .....

Per la Fondazione Operate (presa visione): ..... Data: .....